

계약을 다 해도 상용은 절반입니다

이번 턴에 실제 사고 두 건이 나왔습니다 — 인증 없이 누구나 **운행 로그·영상을 올릴 수 있는** 자리 4개, 그리고 발급된 API 키 하나가 **원본 영상 스트림에 달고 있었습니다**(계약 11조 정면). 둘 다 막혔습니다. **계약 질 진척은 0**입니다 — 사고 처리는 계약 질을 갇지 않습니다. 그게 정직한 보고입니다.

D-346 · 상용 오픈 기준 신설

계약에 없어서 지금까지 대장에도 없던 것들

계약서 어디에도 「익명이 영상을 못 올린다」는 없습니다. 부하시험 0건 · 백업·복구 없음 · 관리 UI 미착수 · 법·인증 준비 초기 — 전부 계약 밖이고 상용에는 필수입니다. **오늘부터 대장에 있습니다.**

428

passed (직전 399)

15 → 0

익명 도달 자리

7 → 1

키 소비 면

v3.2 → v3.3

150 → 158

진척이 아니라 사고입니다

사고 ① 주석 처리된 권한 뒤에 열린 문 15자리

상급 판정

권한 계열 320자리 중 주석 39자리를 인증 관문 유무로 갈랐더니 authn_only 24자리(익명 401)와 no_authn_no_authz 15자리로 나뉘었습니다. **익명**이 핸들러에 달았습니다 — 3자리는 200과 데이터를 반환, 4자리는 **유행 로그·영상 익명 업로드**. 영상 업로드 면이 익명에게 열려 있었다는 것은 계약 11조 인접 사안입니다. 반출이 아니라 유입이지만, **남의 영상을 우리 저장소에 심을 수 있었다**는 뜻입니다.
★ POST 7자리를 「핸들러 도달 표시용 대체물」로 바꿔 때면 것 — **웁습니다**. 본체를 돌리지 않고 도달만 켜 것은 시험 설계로서 정확합니다. 이 기법을 정본으로 올리십시오.

사고 ② inbound API Key 과범위 — 키 하나가 원본 영상에 달았다

상급 판정

dj-core가 X-API-Key를 이미 받고 있었고, 키 하나가 F-05 진입면 7자리 전부에 달았습니다. 거기에 /clip/stream **원본 영상**이 있었습니다 — **계약 11조 정면입니다**.
「인증 자체는 성했고, 성하지 않은 건 범위였다」 — 네 표현이 정확합니다. inbound_api_key.py 기본값 거절 + 열린 곳을 GET /api/dsm/events 하나로 줄인 것, 웁습니다.

★ 그리고 제가 틀렸습니다. 저는 D-335에서 「**남은 일은 만들기가 아니라 잇기**」라고 썼습니다. 실제로는 이미 이어져 있었고, 너무 넓게 이어져 있었습니다. 일은 「**좁히기**」였습니다.

원칙 「없다」고 가정하기 전에 「너무 많이 있다」를 의심한다

D-333의 세 번째 얼굴

① 밖에 사라 가기 전에 안을 뒤진다 · ② 만들기 전에 이미 있는지 뒤진다 · ③ 이미 있으면, 그것이 얼마나 열려 있는지부터 쟀다

★ 만들지 않은 것은 고장 나지 않습니다. 그러나 이미 있는 것은 이미 고장 나 있을 수 있습니다.

§ D-345 · 절 표가 안 움직인 것 — 그것이 정직한 보고입니다

「이번 산출물이 전부 기반·게이트·사고 처리라 계약 절을 갖지 않았습다」 — 정확합니다. 여기서 절을 억지로 갖은 것처럼 적었으면 그게 D-249(부착물을 완성으로)의 재발이었습니다.

보고 규약 — 매 턴 두 줄로 적습니다. 계약 진척 : 절 n/39 (이번 턴 +k) / 기반 진척 : 사고 n건 · 게이트 n종 · 대장 n건
합쳐서 하나의 %로 내지 마십시오. 합치는 순간 어느 쪽도 알 수 없게 됩니다.

착시 ⑦ · 동음이의 4번째 · 측정 재현성

"고침 뒤에도 2자리가 200이었고, `cache.clear()` 뒤 0이 됐습니다."

이건 **결가지가 아닙니다**. 고치고 확인했는데 여전히 열려 있던 것이고, 캐시가 없었다면 「고쳤다」로 보고됐을 것입니다.

D-341 초록의 착시 ⑦ — 캐시의 착시

착시 신설

측정 대상과 측정 시점 사이에 긴 상태가 결과를 대신 답한다. 응답 캐시만이 아닙니다 — 모듈 임포트 캐시 · ORM 쿼리 캐시 · 브라우저 캐시 · CDN · 컨테이너 이미지 레이어 · `__pycache__` 전부 같은 병입니다.

규약 — 모든 회귀·보안 시험은 캐시를 우회하거나 비우고 때립니다. 시험 로그에 「캐시 처리: 우회 / 비움 / 해당 없음」을 한 줄로 남기고, 비면 게이트가 죽습니다.

이건 D-301(검사 못함 ≠ 0건 검사)의 사촌입니다. 거긴 못 보고 초록, 여긴 옛것을 보고 초록.

`verify_cache_bypass.py` — 캐시 처리 표기 없는 보안·회귀 시험 건수 출력. 기존본 래치(D-311), 새 시험 100% 의무. ★ D-310 자기표본: 이번에 200을 내던 그 2자리를 fixture로 박아라

§ 착시 — 이제 일곱 형입니다

형	이름	무엇을 대신 답하나
① ~ ⑤	부착물 · 시나리오 수 · 모수와 술어 · 탐지기 자체 · 환경	기존
⑥	스키마 (D-304)	필드가 있으면 기능이 있다고 읽는다 — <code>clip_path</code>
⑦	캐시 (D-341 신설)	고침이 반영되기 전에 고쳤다고 읽는다 — 200을 내던 2자리

D-342 `authn ≠ authz` — 대장이 만든 턴에 값을 했다

동음이의 4번째

「권한(`path_permission`)」과 「인증(`auth=`)」은 같은 이름이 아니었습니다 — 이 구분이 15자리를 드러냈습니다.

★ 기록해 둡니다: D-337에서 대장을 만들었고, 그 다음 턴에 대장이 사고를 찾아냈습니다. 도구가 첫 사용에서 값을 한 것은 D-310(자기표본)의 반대 증명입니다 — 잘 만든 도구는 즉시 묻니다.

명명 규정 — 코드·시험·문서에서 `auth`를 단독으로 쓰지 마십시오. `authn_ / authz_`로 씁니다.

D-344 「같은 수가 아니면 같은 술어가 아니다」

원칙 신설

임계값 전수가 실측 610/127(직전) → 실측 614/131(이번). 차이 4/4. 자기 변경분 기여 0건을 확인하고 어느 쪽이 맞는지 모른다고 덮지 않고 올린 것 — 읍습니다. 덮었으면 다음 판정이 틀린 분모 위에 썼을 것입니다.

원칙: 수를 보고하는 도구는 재현 가능해야 한다. 같은 커밋에서 두 번 돌려 다른 수가 나오면, 그건 수를 세는 도구가 아니라 추정하는 도구입니다.

① 같은 커밋에서 재현 → 같은 수면 원인은 그 사이의 코드 변경. 무엇이 늘었는지 4건을 이름으로 대라 ② 다른 수면 원인은 술어의 비결정성(순회 순서·캐시⑦·병렬·정규식 백트래킹). 고치고 자기표본에 박아라 ③ 어느 쪽이든 측정 스크립트를 커밋하고 게이트가 두 번 돌려 같은 수인지 검사

이건 D-301의 다음 계단입니다 — 건수를 내는 것으로 부족하고, 그 건수가 재현되어야 합니다.

X-API-Key 전면 적용 — 합니다. 단, 대장을 통과시켜서

「좁히는 DSM 진입면에만 걸었습니다. X-API-Key는 여전히 다른 모든 라우트에서 인증됩니다 — 발급된 키 하나가 지금도 시스템 대부분에 닿습니다.」

판정: 전면 적용합니다. 이 상태를 남겨 둘 수 없습니다 — 사고 ②가 DSM 진입면에만 좁혀진 채로 남아 있다는 뜻입니다. 그러나 수백 개 라우트를 한 번에 뒤집으면 무엇이 깨졌는지 모르는 채로 초록이 됩니다. 순서를 줍니다.

- 1 라우트 인벤토리 전수 — 경로 · 메서드 · 현재 인증 수단 · X-API-Key 수용 여부 · 테넌트 범위 검사 유무. **건수를 출력하라**. 나는 그 수를 모른다 — **실** **속**으로 답하라 이번 턴
- 2 분류 3갈래 — inbound_key_allowed(외부 App이 부를 면) / session_only(사람 UI 전용) / internal_only(내부 호출 전용)
★ 분류의 기본값은 session_only. 판단이 서지 않으면 좁은 쪽으로 넣어라 이번 턴
- 3 기본값 거절을 전역 미들웨어로 — inbound_key_allowed 목록만 통과 ★ **하지 마라** — 인벤토리를 보고 내가 범위를 판정한다
- 4 래칫(D-311) — 목록은 이름으로 고정. 새 라우트가 목록에 없이 키를 받으면 exit 1
- 5 부작위 시험(D-300) — 키로 들어온 요청이 영상·타 테넌트 식별자에 닿는 경로 0건

★ ①의 인벤토리는 버리지 마십시오. 그 표가 곧 ① F-05 연동 규격서의 부록 ② 상용판 API 문서의 초안 ③ 다음 파트너 기술 검토 자료입니다. 한 번만 들어 세 번 씩입니다.

§ 「빈DB」 확인 — 우리가 못 고치는 것

D-207 §0.4

「빈DB」 = dj-core logger/0009 의존 미션언 — 금지구역이라 우리가 못 고칩니다 **실속**.

처리: blockers에 그 사유로 고정하고, 우회 경로(마이그레이션 순서 고정 스크립트)를 우리 층에 두십시오. 금지구역 안으로 손을 넣지 마십시오(D-207). 우회는 우리 층에서, 원인은 대장에 납깁니다.

§ D-347 · 피드백 콘솔의 화면은 실제 캡처만

그림·모형·합성 금지

★ **이유: 이 페이지는 고객이 봅니다.** 여기에 실재가 아닌 화면이 한 장이라도 들어가면, 그건 착시가 아니라 거짓말입니다. D-284(거짓 성공 금지)의 대외 판입니다.

#	수집 규약	내용
①	E2E 실행 중에 찍는다	별도로 화면을 만들어 찍지 마라 — 시험이 지나간 그 화면이어야 한다
②	메타 4칸 동반	route · user_role · scenario(E2E-1/2/3 및 단계) · captured_at
③	에러 화면도 그대로	「에러 없는 스크린샷」은 에러를 지운 화면이 아니라 에러가 나지 않는 상태에서 찍은 화면이다. 에러가 나면 고친 뒤 다시 찍는다
④	개인정보·실영상 금지	시험 데이터만 (계약 11조 · D-269)
⑤	파일	evidence/screens/<scenario>/<role>/<route>.png · 폭 1440px · PNG

산출: evidence/screens/INDEX.yaml — 메타 4칸 + 파일 경로. 제가 이 인덱스를 읽어 콘솔에 채웁니다.

강제 도구 verify_screens.py — 파일 실재 · 메타 4칸 · E2E 로그의 그 단계와 시각이 맞는지(±5분). 어긋나면 exit 1. ★ 이게 없으면 「E2E 중에 찍었다」가 진술로만 납습니다(D-323).

두 개의 축으로 잹니다

계약 이행 · 에스비정보기술 · 2027.1 통합시험

69%

실측

계약 기능 39개 절 중 27개 구현 + 증명 시험 부착
잔여 12절 — 미착수 4 · 잠김 8(SDN·영상재생·구역판정)

상용 서비스 오픈 · GuardianX 제품

≈45%

추정

8영역 가중 합계 · 계약에 없지만 상용에 필수인 것 포함
이 수는 하한입니다 — ②~⑧을 실측으로 같아 끼우면 움직입니다

★ 이 격차가 오늘의 요점입니다 — 계약을 다 해도 상용은 절반입니다. 계약서 어디에도 「의명이 영상을 못 올린다」는 없습니다. 그런 것이 상용에는 필수이고, 계약에 없어서 지금까지 대장에도 없었습니다. 오늘부터 있습니다.

§ 상용 오픈 8영역

가중치·항목은 판정 · 현재 상태는 Code가 실측으로 교체

① 기능 완결성	20%		69%	실측
② 보안	20%		45%	추정
③ 격리·다중테넌시	10%		80%	추정
④ 운영	15%		25%	추정
⑤ 성능·확장	10%		10%	추정
⑥ 품질	10%		70%	추정
⑦ 사용성	10%		20%	추정
⑧ 법·인증	5%		15%	추정

영역	지금 있는 것	남은 것 — 이것이 상용까지의 거리
① 기능	계약 39절 중 27절 + 증명 시험 59건	잔여 12절 · 상용 전용 기능(다중 현장·역할 확장) 미정의
② 보안	테넌트 격리 15→0 · 익명 도달 15→0 · 키 소비 면 7→1 · 게이트 26중	키 전면 적용(D-343) · 침투시험 0건 · 운영서버 9200/5601 노출 · 키 회 전 절차
③ 격리	WP-2 봉인 완료 · 게이트 상시 · 6테넌트 교차 시험	신규 면마다 재검 · 키 인증 경로의 격리 증명
④ 운영	설치·운영 매뉴얼 v0.1 (빈 DB에서 세워 보며 작성)	백업·복구 절차 0건 · 모니터링·알림 0건 · 장애 대응 절차 0건
⑤ 성능	GPU 캐파 설계 문서	부하시험 0건 · 동시 스트림 상한 미측정 · 지연 목표 미정의
⑥ 품질	428 passed · E2E 23 · 게이트 7 + 검증 26중 · 부작위 시험	캐시 우회(D-341) 이제 시작 · 측정 재현성(D-344) · 회귀 자동화
⑦ 사용성	기존 관제 화면	관리 UI 미착수(카메라 주소도 커맨드) · 온보딩 · 사용자 매뉴얼
⑧ 법·인증	GS인증 준비 가이드 · 서류 패키지 초안	개인정보 처리방침 · 영상정보처리기기 고지 · GS인증 본심사 · SLA·과 금 정책

지시 — ②~⑧의 추정을 실측으로 같아 끼우십시오. 방법은 D-314(절 분해) 그대로 — 각 영역을 절로 쪼개고, 절마다 「구현 / 미착수 / 잠김」과 증명 시험 경로를 적습니다. ★ 증명이 없는 칸은 '구현'으로 적을 수 없습니다. 그런 칸은 '미측정'입니다.
강제 도구 verify_ga_readiness.py — 8영역 · 절 단위 · 가중 합계 출력. '부분' 금지(D-314).
★ 초효율 — 이 표가 ① 상용 로드맵 ② 투자·영업 자료 ③ GS인증 준비 체크리스트 ④ 계약 작업이 상용을 얼마나 밀어주는지의 지도. 한 번 만들어 네 번 씁니다.

실행 순서

- 1 D-340~347 정서 — v3.2/150 → v3.3/158 · 각 결정문에 강제 도구 기입 D-286
- 2 캐시 우회 규약 — 보안·회귀 시험에 캐시 처리 표기 · verify_cache_bypass.py · 자기표본에 200을 내던 그 2자리 박기 D-341
- 3 ★ 라우트 인벤토리 전수 + 3갈래 분류 — 실측 건수 출력. 기본값 session_only. 전역 적용은 하지 마라 — 인벤토리를 보고 내가 범위를 판정한다 D-343 ①②
- 4 측정 재현성 — 610/127 vs 614/131 원인 규명 · 측정 스크립트 커밋 · 2회 실행 동일성 게이트 D-344
- 5 동음이의 대장 4번째 등재 · authn_/authz_ 명명 정정 D-342
- 6 ★ 상용 오픈 기준 절 분해 — 8영역을 절로 쪼개고 verify_ga_readiness.py. ②~⑧의 추정을 실측으로. 이번 턴의 주 결과물 D-346
- 7 ★ 스크린샷 수집 — E2E 실행 중 캡처 · INDEX.yaml · verify_screens.py D-347
- 8 보고 규약 적용 — 계약 진척 / 기반 진척 두 줄로 D-345
- 9 커밋 — D-327 술어로 네가 나눠라. 사고 처리는 별도 커밋 권장 D-327 · D-339
- 10 여기서 멈춘다. ③의 인벤토리와 ⑥의 절 표를 보고 다음을 정한다 보고 후 판정

※ VIDEO 구간 추출 · ZONE 폴리곤은 ⑥ 결과와 함께 순서를 정합니다. · ※ 「빈DB」는 blockers에 dj-core 의존 미션언으로 고정하고 우회는 우리 층에서.

§ 대표개 — 표 하나와 콘솔 하나를 함께 올립니다

① 사고 두 건이 실제로 있었습니다. 인증 없이 누구나 운행 로그와 영상을 올릴 수 있는 자리 4개가 있었고, 발급된 API 키 하나가 원본 영상 스트림에 달고 있었습니다(계약 11조 정면). 둘 다 막혔고, 막힌 것을 재호출로 확인했습니다. 기록은 INCIDENT.md에 남습니다. 이번 턴에 계약 기능 진척은 0입니다. 그게 정직한 보고입니다 — 사고 처리는 계약 절을 갓지 않습니다.

② 완성율을 두 축으로 나눠 보고드립니다. 계약 이행 69% 실측 · 상용 서비스 오픈 약 45% 추정. 이 격차가 오늘의 요점입니다. 성능 부하시험 0건, 백업·복구 없음, 관리 UI 미착수, 법·인증 준비 초기 — 그 절반의 내용입니다. 이 항목들은 계약서에 없어서 지금까지 대장에도 없었습니다. 오늘부터 있습니다.

③ 피드백 콘솔을 만들었습니다. 왼쪽에서 사용자와 기능을 고르고, 가운데 화면 위에 직접 그려서 표시하고, 오른쪽에서 전문가·사용자·QA가 의견을 담니다. 보내기를 누르면 그 자리에 저장되고, 제가 다음 지시서에 그대로 반영합니다. 다만 화면은 아직 비어 있습니다. 스크린샷은 Code가 E2E 시험을 돌리면서 그 화면을 찍어 채웁니다. 제가 그림으로 만들어 넣지 않았습니다 — 고객이 보는 자리에 실재가 아닌 화면이 들어가면 그건 착시가 아니라 거짓말이기 때문입니다. 콘솔에 빈 자리가 몇 개인지 숫자로 표시되니 채워지는 것이 보일 겁니다.